Pacote para o jurídico: avaliação e ciência (06/11/2026)

Sistema: chat de atendimento da CSI - Clínica de Saúde e Imagem (chat do paciente, painel da equipe, "Minha vez"/fila e "Meus dados"). Projeto Supabase `nrvuynjwcgwpjdptkiay`, região **sa-east-1 (São Paulo)**, conferida hoje.

Volume hoje no banco real: 39 conversas, 13 pacientes, 8 contas de login, **0 fotos de pedido, 0 atendimentos na fila, 0 assinaturas**. Ou seja, os dois módulos mais sensíveis (foto lida por IA e assinatura biométrica) ainda não receberam dado real.

1. Textos para o jurídico revisar e aprovar

Documento	Onde	Observação
Política de Privacidade	`privacidade.html`	"Texto-base em revisão jurídica", atualizado em 02/11/2026
Termos de Serviço	`termos.html`	idem
Caixas de aceite do formulário e do cadastro (consentimento geral, texto do responsável legal por criança, autorização específica da foto do pedido)	`index.html` (procure por "consent" e "responsável")	Art. 7º, 11 e 14 da LGPD
Textos da tela "Meus dados" (o que sai, o que fica, canal de pedido)	`index.html` e `supabase/meus-dados.sql`	Exclusão apaga a conta, mas cadastro e registros de saúde ficam
Frases do chat sobre a foto ("A foto fica guardada...") e avisos de preço/valor	`index.html`, `docs/fase8-leitura-do-pedido.md`	Item 13 de `pendencias.md` (promessas)

Pontos desatualizados que o jurídico deve saber (a política foi escrita antes de mudanças):

- A política cita **n8n** como operador. O n8n **saiu do projeto em 03/11/2026**. Confirmar se algum dado ficou lá e se precisa ser apagado.
- A política cita só "provedor de inteligência artificial". O provedor é a **Anthropic**. O e-mail do link da fila usa **Resend**. Os avisos no celular usam **Web Push** (serviços do Google, Apple e Mozilla). Nenhum dos três é nomeado.
- Os Termos dizem que parte do atendimento é feita por IA. Pela documentação (`docs/plano-fase7-fluxo-sem-ia.md`), o chat hoje roda em fluxo roteirizado (`config.motor = 'fluxo'`), sem IA conversando. A IA só entraria na leitura da foto, que está desligada. Decidir como o texto deve ficar.

2. Decisões que só o jurídico/clínica pode tomar

1. **CNPJ** e **e-mail do encarregado (DPO)**: hoje "a informar" nas duas páginas, no rodapé do chat e em "Meus dados".
2. **Prazo de retenção** de conversas, fotos de pedido e dados de contato (a política diz "em revisão jurídica"). Prontuário já está em 20 anos (Lei 13.787/2018).
3. **Exclusão total**: decidir o que apagar e criar um canal registrado de pedidos (hoje é só WhatsApp).
4. **Dados mínimos**: CPF, data de nascimento e endereço são realmente obrigatórios para o agendamento? (CPF já é opcional no chat.)
5. **Aviso de cookies**: o site não usa cookies de rastreamento; decidir se entra banner informativo.
6. **Propriedade do logo e ícones** da CSI.
7. Revisão final da **copy** (promessas sobre segurança, valores e cobertura de convênio).

3. Módulos bloqueados até aprovação (não ligar com paciente real)

3.1 Leitura da foto do pedido por IA (`supabase/functions/ler-pedido`, `docs/fase8-leitura-do-pedido.md`)

- Pedido médico é **dado de saúde (art. 11)**. A foto é enviada à **API da Anthropic**, que atuaria como operadora, e a leitura da IA fica guardada em `conversa_anexo`.
- O que falta: texto de consentimento específico, prazo de retenção da foto e da leitura, **RIPD**, **contrato/DPA com a Anthropic**, base para **transferência internacional (art. 33)** e aviso na política. Também o uso das fotos para "ensinar" o sistema (view `ocr_treino`) precisa de base legal própria.
- A função só roda com o secret `ANTHROPIC_API_KEY`; sem a chave, fica desligada.

3.2 Assinatura biométrica da fila (`docs/fila-biometria.md`, seção 8)

- Traço da assinatura é **dado biométrico sensível (art. 11)**; a coluna `vetor_traco_bruto` guarda a série completa e `registro_assinaturas` é imutável.
- O que falta: consentimento revisado, prazo de retenção e rotina de apagamento, **RIPD**, definir quem da equipe pode ler os registros. O limiar 0,30 é permissivo: é reforço, **não prova de identidade**.
- Observação: a imutabilidade do registro pode conflitar com pedido de eliminação (art. 18). O jurídico deve opinar.

4. Contratos de operadores e transferência internacional

Pedir ou confirmar contrato/DPA e local de armazenamento de cada um:

Fornecedor	Para quê	Dado envolvido
Supabase	Banco, login, funções (região São Paulo)	Tudo
GitHub Pages	Hospedagem das páginas	IP do visitante
Klingo	Agenda e cadastro da clínica	Cadastro, marcações, status
Anthropic	Leitura da foto (desligada)	Foto do pedido (saúde)
Resend	E-mail do link da fila	Nome e e-mail
Cloudflare Turnstile, jsDelivr, ViaCEP	Anti-robô, bibliotecas, busca de CEP	IP e CEP
Web Push (Google/Apple/Mozilla)	Avisos no celular	Identificador do aparelho
n8n (descontinuado)	Antigo orquestrador	Confirmar exclusão

5. Para ciência: fluxos de dados que o jurídico deve conhecer

1. **Leitura contínua do Klingo** (a cada minuto no expediente): só status de marcação (confirmou, chegou, faltou, remarcou, cancelou). O telefone não é gravado (vira uma marca) e o valor em R$ não é lido. `docs/jornada-monitoramento.md`.
2. **Junção automática de conversas da mesma pessoa** (nome + 2 informações; nunca une mãe e filho). Decisão automatizada com possibilidade de separar: avaliar frente ao art. 20. `docs/pessoa-unica.md`.
3. **Minha vez / Jornada**: o paciente logado vê os exames do Klingo só após a recepção conferir a identidade. `docs/jornada-paciente.md`.
4. **Menores**: agendamento feito por responsável legal, com aceite próprio.
5. **Registros técnicos de erro** (Sentinela): sem texto de mensagem, CPF, telefone ou e-mail.
6. **Acesso da equipe**: painel com perfis; foto do pedido visível ao atendente. Definir política de acesso e de logs.

7. **Segurança**: acesso por token da conversa, regras no banco (RLS). Auditoria técnica em `docs/auditoria-2026-10-30.md`.
8. **Plano de incidente**: a política promete avisar paciente e ANPD. Falta procedimento interno documentado.

6. Anexos a enviar

- `privacidade.html` e `termos.html` (ou os links publicados)
- `pendencias.md` (lista dos 17 itens de conformidade e bloqueios)
- `docs/fase8-leitura-do-pedido.md` (seção da IA e da foto)
- `docs/fila-biometria.md` (seções 1 e 8)
- `docs/jornada-monitoramento.md`, `docs/pessoa-unica.md`, `docs/jornada-paciente.md`
- `docs/auditoria-2026-10-30.md` (segurança)
- Este documento

7. O que pedir de volta ao jurídico

Parecer ou ciência por escrito sobre: textos aprovados (ou com alterações), prazos de retenção, CNPJ e DPO, RIPD (foto por IA e biometria), contratos dos operadores, e autorização para ligar (ou manter desligados) os dois módulos sensíveis.